

**HỌC VIỆN CÔNG NGHỆ BƯU CHÍNH VIỄN THÔNG
KHOA AN TOÀN THÔNG TIN**



**BÁO CÁO BÀI TẬP LỚN
HỌC PHẦN: MẬT MÃ HỌC CƠ SỞ
MÃ HỌC PHẦN: INT1344**

LAB: BLS-BFT

Các sinh viên thực hiện:

B22DCAT063 Lê Tiến Dương

B22DCAT073 Lê Thành Đạt

Tên nhóm: 05

Tên lớp: 04

Giảng viên hướng dẫn: PGS. TS. Đỗ Xuân Chơ

HÀ NỘI 3-2025

LAB: BLS-BFT

1. Giới thiệu chung về bài thực hành

Tên bài thực hành: Tấn công giao thức đồng thuận BLS trong hệ thống BFT.

Giao thức BLS được dùng trong các hệ thống đồng thuận BFT để xác minh các thông điệp hợp lệ qua chữ ký tổng hợp. Tuy nhiên, nếu attacker có thể tạo hoặc giả mạo một block hoặc thông điệp không hợp lệ nhưng vẫn được xác thực (ví dụ: dùng chữ ký sai lệch, hoặc replay message), hệ thống có thể ra quyết định sai.

Những lỗ hổng này nếu không được xử lý triệt để sẽ làm suy giảm niềm tin vào hệ thống đồng thuận, tạo điều kiện cho các tấn công phá hoại hoặc chiếm quyền kiểm soát quá trình ra quyết định. Bài thực hành này giúp sinh viên hiểu cách các cuộc tấn công đó diễn ra từ đó phát triển cách phòng thủ.

Mục đích:

- Hiểu cơ chế hoạt động của một hệ thống đồng thuận BFT sử dụng chữ ký BLS.
- Hiểu và mô phỏng cách attacker có thể tấn công bằng cách giả mạo block, giả lập chữ ký, hoặc tái sử dụng thông điệp (replay).
- Quan sát hậu quả của các tấn công khi hệ thống không có biện pháp xác thực chặt chẽ.

Yêu cầu đối với sinh viên:

- Biết sử dụng terminal, câu lệnh Linux cơ bản.
- Đọc hiểu và sửa mã Python mô phỏng hệ thống validator và attacker.
- Biết kiểm tra log, thời gian chạy, cấu hình hệ thống.
- Trả lời các câu hỏi phân tích sau mỗi task.

2. Nội dung thực hành

Trong terminal ban đầu, gõ lệnh:

```
imodule https://github.com/letienduong/labtainer/raw/refs/heads/main/imodule.tar
```

để tải bài lab về.

Sinh viên khởi động bài lab:

```
labtainer -r bls-bft
```

(Chú ý: Sinh viên sử dụng MÃ SINH VIÊN của mình để nhập thông tin người thực hiện bài lab khi có yêu cầu, để sử dụng khi chấm điểm.)

Sau khi khởi động bài lab, 4 container sẽ xuất hiện tương ứng với validator1, validator2, validator3, attacker, sinh viên tiếp tục thực hiện các nhiệm vụ theo yêu cầu.

Nhiệm vụ 1: Kiểm tra kết nối giữa các node

Trong mỗi container ứng với các node, sinh viên sử dụng lệnh *ifconfig* để kiểm tra địa chỉ IP của từng container.

Tiếp theo, sinh viên thực hiện kiểm tra kết nối từ validator2 đến các container khác sử dụng lệnh:

ping <Địa chỉ IP máy đích>

Sau khi ping thành công, sinh viên trả lời câu hỏi: Tại sao việc kiểm tra kết nối lại quan trọng trong một hệ thống phân tán?

Nhiệm vụ 2: Giao tiếp giữa các node

Trong các hệ thống **đồng thuận BFT (Byzantine Fault Tolerant)**, các node (validator) cần liên tục **trao đổi thông tin block** với nhau để tiến tới đồng thuận. Một block có thể được tạo từ một node, sau đó gửi tới các node khác để yêu cầu xác thực, ký xác nhận, và tổng hợp thành một **chứng chỉ đồng thuận (QC – Quorum Certificate)**.

Việc một node lắng nghe block từ các node khác là một hoạt động thiết yếu trong quy trình đồng thuận, nhằm thực hiện:

- Xác minh chữ ký và nội dung block gửi đến.
- Kiểm tra thông tin vòng, leader, loại block.
- Tích lũy chữ ký từ nhiều node khác nhau, đủ quorum thì mới tiến hành tạo QC.

Trong bài thực hành này, validator2 thực hiện lắng nghe block từ nhiều nguồn để tích lũy thông tin và quyết định các bước tiếp theo.

Trước hết, trên terminal của node validator2, sinh viên kiểm tra các file hiện có:

ls

Sinh viên sẽ tìm thấy file *leader.py* trong danh sách file hiện có. File này sẽ mô phỏng hành vi của một leader trong hệ thống đồng thuận BFT, có nhiệm vụ:

- Lắng nghe các chữ ký gửi từ các validator khác.
- Kiểm tra tính hợp lệ của block.
- Tổng hợp chữ ký để tạo thành chứng chỉ đồng thuận (QC) bằng chữ ký BLS.

Tiếp theo, sinh viên chạy file *leader.py* để mở một socket TCP lắng nghe kết nối từ các validator khác gửi chữ ký:

python3 leader.py

Mỗi block có một *block_id*. Nếu leader thấy một block mới có cùng ID nhưng nội dung khác, nó coi đó là mạo danh. Đây là cách phát hiện tấn công kiểu gửi block giả mạo hoặc block bị sửa.

Sau khi chạy file *leader* ở validator2, sinh viên chuyển sang terminal của validator 1 và validator 3 để thực hiện gửi block và chữ ký tới leader (validator2). Sinh viên kiểm tra các

file hiện có, thấy tồn tại file *node.py*. Sinh viên cần thực hiện chạy file này để có thể gửi chữ ký đến validator2 đang trong trạng thái lắng nghe:

python3 node.py

Sau khi thực thi xong file này, sinh viên quay trở lại terminal của validator2 và kiểm tra thông điệp vừa xuất hiện. Sinh viên có nhận xét gì?

Sau khi hoàn thành xong nhiệm vụ này, sinh viên hãy trả lời các câu hỏi sau:

- Điều gì sẽ xảy ra nếu validator1 và validator3 gửi cùng một block với nội dung giống hệt nhau?
- Leader tạo Quorum Certificate (QC) khi nào?
- Nếu chỉ có một validator gửi chữ ký đến leader, leader có thể tạo QC không? Vì sao?

Nhiệm vụ 3: Block giả mạo từ attacker

Trong nhiệm vụ này, sinh viên sẽ thực hiện phân tích và phát hiện một block giả mạo được gửi từ attacker đến validator2. Kẻ tấn công sẽ sử dụng khóa “validator1” để ký block, khiến hệ thống hiểu rằng block đến từ node hợp lệ.

Trong terminal attacker, sinh viên kiểm tra phát hiện file *attack.py*, file này chứa script thực hiện nhiệm vụ giả mạo validator1 gửi chữ ký đến validator2. Tuy nhiên, trong quá trình lập trình, kẻ tấn công đã không kiểm tra kỹ khiến trong file *attack.py* xuất hiện lỗi, từ đó không thể chạy được và gửi chữ ký đến validator2.

Nhiệm vụ của sinh viên trong phần này là kiểm tra lại file *attack.py* và áp dụng kiến thức từ những nhiệm vụ trước để sửa lại file *attack.py* để giúp kẻ tấn công có thể gửi chữ ký giả mạo đến validator2.

Sau khi sửa file *attack.py*, sinh viên chạy lại từ validator2 như nhiệm vụ 2 và lần lượt gửi chữ ký từ validator1 và attacker đến. Chạy lần lượt các lệnh sau ở 3 terminal:

Validator2: *python3 leader.py*

Validator1: *python3 node.py*

Attacker: *python3 attack.py*

Sinh viên quan sát kết quả xuất hiện ở validator2 và tiếp tục cho nhận xét? Sau đó trả lời các câu hỏi sau:

- Block ID mà attacker đã sử dụng là gì? Bạn tìm ra bằng cách nào?
- Nếu attacker sử dụng block ID trùng nhưng nội dung khác so với validator1, điều gì xảy ra?

Nhiệm vụ 4: Tìm hiểu về cách phòng chống kiểu tấn công này

Sinh viên hãy tìm hiểu một số kiến thức về chữ ký số BLS, xác thực danh tính trong hệ thống phân tán, reply attack và cách phòng chống, Quorum Certificate(QC) và cơ chế đồng thuận BFT để đề xuất các phòng chống.

Kết thúc bài lab:

Trên terminal đầu tiên sử dụng câu lệnh sau để kết thúc bài lab:

stoplab

Khi bài lab kết thúc, một tệp zip lưu kết quả được tạo và lưu vào một vị trí được hiển thị bên dưới lệnh stoplab.

Kiểm tra kết quả:

Sinh viên kiểm tra kết quả bài lab sử dụng lệnh:

checkwork bls-bft

Khởi động lại bài lab:

Trong quá trình làm bài sinh viên cần thực hiện lại bài lab, dùng câu lệnh:

labtainer -r bls-bft

